

Dette technique chiffrée — PNPI

*Document interne · Architecture PNPI · Version 1.0 — Avril 2026 Auteur : Jean Baptiste MBA
NDONG (Architecte)*

1. Méthode

Sont listés ici les éléments connus de **dettes techniques actives** : choix provisoires, raccourcis assumés, manques fonctionnels ou non-fonctionnels identifiés à date.

- **Catégories** : Sécurité (SEC), Performance (PERF), Qualité (QUA), Données (DATA), Mobile (MOB), Infrastructure (INFRA), Documentation (DOC), Conformité (CONF), Frontend (FE), Backend (BE).
- **Criticité** : CRITIQUE / HAUTE / MOYENNE / BASSE.
- **Effort** : jours-homme (j-h), tout compris (analyse, dev, tests, doc).
- **Recommandation** : Fix (à corriger), Accept (acceptée tant que...), Contourner (mitigation).

Les efforts sont des estimations **à dire d'expert** d'un développeur senior familier de la stack. Ils n'incluent pas la coordination, les revues externes, les bascules de production.

2. Synthèse

INDICATEUR	VALEUR
Nombre d'items répertoriés	27
Total effort estimé	183 jours-homme
Items CRITIQUES	4 (38 j-h)
Items HAUTS	9 (74 j-h)
Items MOYENS	9 (53 j-h)
Items BAS	5 (18 j-h)
Recommandation Fix	22 (162 j-h)
Recommandation Accept (avec suivi)	4 (16 j-h)
Recommandation Contourner	1 (5 j-h)

Lecture : pour amener la PNPI à un niveau de production institutionnel **sans** aucun trou structurel, il faut compter ~9 mois-homme d'investissement développement. Avec une équipe de 2 développeurs full-time, c'est faisable en 18-22 semaines calendaires.

3. Items CRITIQUES (à fixer avant ouverture officielle)

D-001 — Stockage local des documents ATI (filesystem) sans réplication

- **Catégorie :** INFRA / DATA
- **Description :** `PNPI_UPLOAD_DIR=uploads/ati` est un répertoire local du conteneur. Aucun backup automatisé. Si le volume Docker est perdu, tous les documents joints (justificatifs de capacité, plans d'unités, photos d'inspection) sont perdus.
- **Effort :** 8 j-h (mise en place MinIO + migration + config + tests).
- **Bloquants :** provisioning MinIO ANINF.
- **Recommandation :** **Fix** — migration vers MinIO S3-compatible avec réplication.

D-002 — Absence d'audit de pénétration externe sur la version actuelle

- **Catégorie** : SEC / CONF
- **Description** : aucun pentest externe formel n'a été conduit. Les endpoints `/admin/*` , `/auth/*` , `/pnpi/ati/*` exposent une logique régaliennne sans vérification adverse indépendante.
- **Effort** : 10 j-h (préparation + remédiation moyenne attendue ; le pentest lui-même est externalisé).
- **Bloquants** : sélection prestataire, validation Cabinet.
- **Recommandation** : **Fix** — pentest planifié à J+15 (cf. plan J0-J+90).

D-003 — Pas de chiffrement au repos sur la base PostgreSQL de prod

- **Catégorie** : SEC / CONF
- **Description** : la base de production prévue n'active pas, à ce jour, le chiffrement au repos (TDE / pg_crypto sur colonnes sensibles : NIF, effectif, données personnelles).
- **Effort** : 12 j-h (étude + chiffrement par colonne + KMS + migration).
- **Bloquants** : choix d'un KMS (ANINF ou interne).
- **Recommandation** : **Fix** — exigence CNPDCP.

D-004 — Tests de charge inexistant

- **Catégorie** : PERF
- **Description** : aucun test de charge (k6, Locust) n'a été exécuté. Les hypothèses de capacité (1000 utilisateurs concurrents, 100 ATI/jour) ne sont pas validées.
- **Effort** : 8 j-h (scénarios + jeu de données + remédiation des *hot spots* trouvés).
- **Bloquants** : environnement de pré-production iso-prod.
- **Recommandation** : **Fix** — test de charge à J+25.

4. Items HAUTS

D-005 — Mix `Role` `enum` / chaîne dans la base

- **Catégorie** : QUA / SEC
- **Description** : les rôles utilisateurs sont stockés en `str` dans la table `users.roles` , manipulés en `Role` (StrEnum) en Python. Le helper `_user_role_values(user)` normalise — mais c'est une dette qu'il faut consolider.
- **Effort** : 4 j-h (migration colonne + tests).

- **Recommandation** : Fix.

D-006 — Couverture de test backend ~50 % effective

- **Catégorie** : QUA
- **Description** : 18 fichiers de tests, ~43 tests, mais des routers entiers (graphql_api, push, scheduled_reports, ws) ne sont pas couverts.
- **Effort** : 15 j-h pour atteindre 75 % sur le périmètre régalien.
- **Recommandation** : Fix — priorité aux routers manipulant des décisions ATL.

D-007 — Pas de tests E2E mobile (Flutter)

- **Catégorie** : MOB / QUA
- **Description** : l'app mobile n'a pas de tests d'intégration (flutter_driver / Patrol).
- **Effort** : 12 j-h.
- **Recommandation** : Fix — au moins 5 scénarios critiques inspecteur.

D-008 — Refresh token : rotation non implémentée

- **Catégorie** : SEC
- **Description** : le refresh token actuel n'est pas révoqué/regénéré à chaque usage (best practice OAuth2 RFC 6819).
- **Effort** : 5 j-h.
- **Recommandation** : Fix.

D-009 — Pas de monitoring d'erreurs centralisé (Sentry-like)

- **Catégorie** : INFRA / QUA
- **Description** : les erreurs sont logguées en JSON (Loki/Grafana) mais sans outil de dédoublonnage ni d'alerting fin par release.
- **Effort** : 6 j-h (Glitchtip ou Sentry self-hosted).
- **Recommandation** : Fix.

D-010 — Migration des 36 fichiers Alembic non testée par bascule

- **Catégorie** : DATA
- **Description** : les migrations s'appliquent sur des bases vierges (CI). Aucune bascule réelle d'une base prod-like remplie n'a été rejouée bout-en-bout.
- **Effort** : 8 j-h (backup réel + replay + tests).
- **Recommandation** : Fix.

D-011 — Pas de séparation logique réseau entre back et redis

- **Catégorie** : SEC / INFRA
- **Description** : Redis est dans le même réseau Docker que le backend. Si le backend est compromis, Redis est accessible sans authentification.
- **Effort** : 4 j-h (mot de passe Redis + ACL + isolation VLAN).
- **Recommandation** : Fix.

D-012 — `PNPI_SECRET_KEY` géré par fichier `.env`

- **Catégorie** : SEC
- **Description** : pas de coffre-fort de secrets (Vault, ANINF KMS). Risque sur les opérations DevOps (commit accidentel, lecture par prestataire).
- **Effort** : 10 j-h (Vault self-hosted + intégration FastAPI).
- **Recommandation** : Fix.

D-013 — Pas de plan de bascule (PRA) testé

- **Catégorie** : INFRA / CONF
- **Description** : `docs/prs_pca.md` existe mais n'a jamais été exécuté en grandeur réelle.
- **Effort** : 10 j-h pour un test de bascule supervisé + rapport.
- **Recommandation** : Fix — exigence audit ISO 22301.

5. Items MOYENS

D-014 — Pagination non systématique sur les listes longues

- **Catégorie** : PERF
- **Description** : `core/pagination.py` existe et est utilisé sur certains routers. Quelques endpoints listant des sous-ressources (commentaires, tags, historiques) renvoient encore des listes complètes.
- **Effort** : 5 j-h.
- **Recommandation** : Fix.

D-015 — Index PostgreSQL composite `(status, deleted_at, created_at)` partiels

- **Catégorie** : PERF

- **Description** : la migration 32 a ajouté des index composites mais certaines requêtes du `npqi_dashboard` font encore du seq scan.
- **Effort** : 4 j-h (EXPLAIN + index ciblés).
- **Recommandation** : Fix.

D-016 — Cache Redis sans politique TTL globale formalisée

- **Catégorie** : PERF / DOC
- **Description** : `core/cache.py` permet de mettre en cache mais chaque appelant choisit son TTL ad hoc. Pas de table de référence.
- **Effort** : 3 j-h.
- **Recommandation** : Fix — créer `docs/architecture/cache-policy.md` .

D-017 — frontend : doublons entre `app/components` (28+ composants)

- **Catégorie** : FE / QUA
- **Description** : des composants similaires existent (KPICard variants, StatusBadge, EmptyState multiples). Refactor en design system unique.
- **Effort** : 8 j-h.
- **Recommandation** : Fix.

D-018 — Pas d'i18n côté backend (messages d'erreur)

- **Catégorie** : QUA / FE
- **Description** : les messages d'erreur HTTP sont en français codés en dur. Bloquant pour la version Guinée équatoriale (espagnol).
- **Effort** : 6 j-h (Babel-py + extraction).
- **Recommandation** : Fix — préalable au tenant Guinée Eq.

D-019 — Logs JSON non envoyés à Loki en prod

- **Catégorie** : INFRA
- **Description** : `core/logging_config.py` produit du JSON, mais pas d'agrégateur configuré.
- **Effort** : 4 j-h (Promtail + Loki).
- **Recommandation** : Fix.

D-020 — Frontend : TypeScript `strict: false` sur certains modules

- **Catégorie** : FE / QUA
- **Description** : ~12 fichiers (hooks, composants legacy) ont `// @ts-nocheck` .

- **Effort** : 6 j-h.
- **Recommandation** : **Fix**.

D-021 — GraphQL API exposée mais sans rate limiting fin

- **Catégorie** : SEC / PERF
- **Description** : `routers/graphql_api.py` est derrière le rate limiter global mais pas de query depth limit ni complexity analysis.
- **Effort** : 5 j-h.
- **Recommandation** : **Fix** — ou désactiver le flag `PNPI_FF_GRAPHQL_API` .

D-022 — Pas de documentation OpenAPI publique versionnée

- **Catégorie** : DOC
- **Description** : `/docs` Swagger est exposé mais pas de schema OpenAPI versionné par release pour les futurs intégrateurs CEMAC.
- **Effort** : 12 j-h (CI génération + hébergement Redoc).
- **Recommandation** : **Fix**.

6. Items BAS

D-023 — Configuration ESLint `frontend` permissive

- **Catégorie** : FE / QUA
- **Effort** : 3 j-h.
- **Recommandation** : **Fix** — durcir progressivement.

D-024 — Pas de tests visuels (Chromatic / Percy)

- **Catégorie** : FE / QUA
- **Effort** : 4 j-h.
- **Recommandation** : **Accept** — coût/valeur faible à court terme.

D-025 — Pas de génération automatisée de PDF pour les rapports

- **Catégorie** : FE
- **Description** : `routers/exports.py` génère du XLSX/CSV. Le PDF d'arrêté est généré côté backend mais sans templating riche.

- **Effort** : 5 j-h (WeasyPrint + templates).
- **Recommandation** : **Fix** — préalable à la signature qualifiée ADR-005.

D-026 — Code Flutter : pas de séparation `domain/data/presentation`

- **Catégorie** : MOB / QUA
- **Effort** : 4 j-h (refactor partiel).
- **Recommandation** : **Accept** — surface de l'app reste modeste.

D-027 — Pas de bannière de cookie / consentement RGPD CEMAC

- **Catégorie** : CONF / FE
- **Effort** : 2 j-h.
- **Recommandation** : **Fix** — préalable au tenant Cameroun.

7. Plan d'action recommandé

Sprint 0 (J+1 → J+30 — pré-ouverture officielle)

- D-001, D-003, D-008, D-011, D-012 — **39 j-h**, 1,5 dev × 4 sem.

Sprint 1 (J+30 → J+60 — stabilisation)

- D-002 (pentest), D-004, D-006, D-009, D-010 — **49 j-h**.

Sprint 2 (J+60 → J+90 — hardening + qualité)

- D-005, D-007, D-013, D-014–D-022 — **63 j-h**.

Sprint 3 (post-J+90 — finition)

- Items BAS + résiduel — **18 j-h**.

8. Ce qui n'est *pas* dans ce document

- Les évolutions fonctionnelles demandées par les utilisateurs (cf. `docs/strategie/05-questions-cabinet.md`).

- La dette stratégique (posture juridique, modèle économique) — couverte par le dossier stratégique.
 - La dette de produit (parcours utilisateurs, UX) — à traiter par un audit UX dédié.
-

Fin du document.
